

AWS Study Guide

按服务职责整理的 AWS 核心概念速查。阅读时先判断题目在解决什么问题，再选择服务，而不是只记服务名。

目录

- 1. 先建立整体框架
- 2. 存储与数据迁移
- 3. 数据处理、分析与可视化
- 4. 数据库与缓存
- 5. 消息、事件与 Serverless
- 6. 网络、负载均衡与全球加速
- 7. 身份、密钥与安全
- 8. 监控、审计、合规与成本
- 9. 计算容量与系统运维

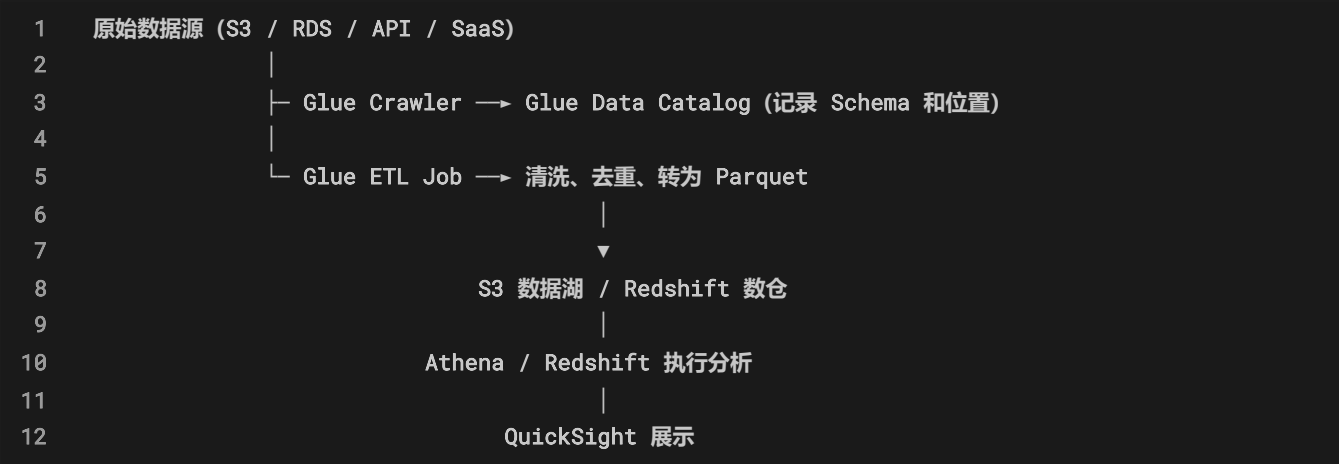
1. 先建立整体框架

1.1 用“职责”识别服务

需求	首先想到	核心作用
存放文件或数据湖原始数据	Amazon S3	对象存储
直接用 SQL 临时查询 S3	Amazon Athena	Serverless 查询引擎
清洗、转换、编目数据	AWS Glue	ETL 与元数据管理
长期、高频、复杂 BI 分析	Amazon Redshift	数据仓库
运行 Spark/Hadoop 等大数据框架	Amazon EMR	托管大数据计算平台
展示 BI 图表和报表	Amazon QuickSight	数据可视化
缓冲异步任务	Amazon SQS	消息队列
一条消息广播给多个系统	Amazon SNS	发布/订阅
缓存全球静态内容	Amazon CloudFront	CDN
优化全球动态网络路径	AWS Global Accelerator	网络加速与跨区故障转移

需求	首先想到	核心作用
查看资源配置是否合规	AWS Config	配置历史与规则检查
追查谁调用了 AWS API	AWS CloudTrail	API 活动审计

1.2 一条典型数据分析链路



核心区别：S3 负责“存”，Glue 负责“整理”，Athena/Redshift 负责“查”，QuickSight 负责“看”。

2. 存储与数据迁移

2.1 Amazon S3：对象存储

- **对象 (Object)**：文件内容及其元数据。
- **桶 (Bucket)**：对象的顶层容器，不等于普通文件夹。
- **前缀 (Prefix)**：对象 Key 中类似目录的部分；控制台用它模拟文件夹。
- 可存放 JSON、CSV、Parquet、日志、图片、静态网页等。
- S3 主要负责持久存储，本身不是数据库。

静态网站托管

S3 可直接托管 HTML、CSS、JavaScript 和图片，成本低、运维少；它不能运行 PHP、Java、Node.js 等服务端代码。全球分发通常在前面加 CloudFront。

存储类型

类型	适用场景	关键限制 / 特点
S3 Standard-IA	低频访问，但需要立即取回	跨多个 AZ；读取收费
S3 One Zone-IA	可重新生成、无需 AZ 容灾的数据	只存一个 AZ，更便宜
S3 Intelligent-Tiering	访问规律无法预测	自动在访问层级间调整
S3 Glacier Instant Retrieval	很少访问，但取用时毫秒级返回	适合“冷但要立刻拿”
S3 Glacier Deep Archive	长期合规归档，几乎不访问	成本极低，恢复通常需数小时

使用 S3 Lifecycle 可自动转换存储层或到期删除对象，例如：数据先放 S3，14 天后转入 Glacier。文件内容应存入 S3；DynamoDB 更适合保存文件的 Key、状态等元数据，单个 Item 最大约 400 KB。

数据保护与跨区复制

- **Versioning**：覆盖或删除对象后仍保留旧版本，可用于恢复误操作。
- **MFA Delete**：永久删除对象版本或更改 Versioning 状态时要求 MFA。必须先启用 Versioning，而且只能由桶的 root 账户通过 CLI/API 启用或停用。
- **Object Lock**：基于 Versioning 实现 WORM（Write Once Read Many）。Governance Mode 可由具备特殊权限者绕过；Compliance Mode 在保留期内连 root 也不能删除或修改。Retention Period 设置到期时间，Legal Hold 则持续到人工解除。
- **Cross-Region Replication（CRR）**：把源桶对象自动复制到另一 Region，适合异地备份、合规或降低跨区读取延迟。

Lifecycle 负责“何时转层或过期”，Object Lock 负责“能否改删”，两者不能互相替代。

S3 数据访问与传输

需求	方案	要点
全球客户端更快上传到一个 S3 Region	S3 Transfer Acceleration	从就近 Edge 进入 AWS 骨干网；优化“上传”
私有子网访问 S3，并减少 NAT 费用	S3 Gateway Endpoint	不经过 NAT；Endpoint 本身无小时费和数据处理费
海量数据因带宽不足无法走网络	Snowball Edge Storage Optimized	用 AWS 寄送的物理设备传 TB/PB 级数据
跨账号下载时由请求方承担请求与传输费用	S3 Requester Pays	请求方必须经过身份认证；桶主仍承担存储费

2.2 块存储、文件存储与混合云文件服务

服务	存储模型	典型用途
Amazon EBS	单 AZ 块存储	类似一台 EC2 的硬盘
Amazon EFS	共享文件存储 (NFS)	Regional EFS 可让多 AZ 的 Linux EC2 共享文件，并自动扩缩容量
FSx for Windows File Server	托管 Windows 文件存储 (SMB)	Windows ACL、Active Directory; 可选 Multi-AZ
FSx for Lustre	高性能 Lustre 文件系统	HPC、机器学习和大规模计算; 可关联 S3
FSx for NetApp ONTAP	NFS、SMB、iSCSI	NetApp 工作负载迁移
FSx for OpenZFS	NFS	ZFS/Linux 文件服务器迁移
S3 File Gateway	本地 NFS/SMB，后台对象存入 S3	本地文件服务器与 S3 的混合云接入
FSx File Gateway (旧场景)	本地 SMB 缓存，后台访问 FSx for Windows	保留本地 Windows 访问体验并降低热数据延迟; 已不再向新客户开放

FSx for Lustre 的 Scratch 部署偏临时高性能，Persistent 部署适合长期数据；EFS 不能“配置成 Lustre”。

EBS 快照与性能

- **跨 Region Snapshot**：复制 EBS 快照后，可在目标 Region 创建新 Volume；适合磁盘备份和迁移。
- **Fast Snapshot Restore (FSR)**：新 Volume 从创建起就有完整性能，避免首次读取块时的初始化延迟。
- **Multi-Attach**：部分 io1/io2 Volume 可同时挂载到多个 EC2，解决特殊的共享块存储需求；它不是数据复制功能。
- **Provisioned IOPS SSD**：可明确配置高而稳定的 IOPS，适合高 I/O、延迟敏感、持续随机读写的大数据库。若瓶颈明确是磁盘 I/O，单纯增加内存或 Read Replica 未必能解决。

2.3 数据迁移工具

场景	选择
On-prem NFS/SMB 与 S3、EFS、FSx 间高速或定时同步	AWS DataSync
本地用户继续使用 NFS/SMB，但底层希望存到 S3	S3 File Gateway
现有客户让本地 Windows 用户通过缓存访问云端 FSx for Windows	FSx File Gateway (不再向新客户开放)
网络带宽不足，需要一次性迁移 TB/PB 数据	Snowball Edge
SaaS (如 Salesforce、SAP、ServiceNow) 与 AWS 间传数据	Amazon AppFlow
数据库持续或一次性迁移到 AWS	AWS Database Migration Service (DMS)

DataSync 面向文件/对象数据，支持自动增量传输、加密和完整性校验；DMS 面向数据库，两者不要混淆。

3. 数据处理、分析与可视化

3.1 Athena、Redshift、Glue 与 EMR

维度	AWS Glue	Amazon Athena	Amazon Redshift	Amazon EMR
核心角色	ETL 与元数据管理	S3 即席 SQL 查询	企业级 OLAP 数仓	托管大数据计算平台
适合任务	清洗、转换、编目	按需、低频探索	高频复杂 BI 分析	Spark/Hadoop/Hive 工作负载
是否存业务数据	Data Catalog 只存元数据；Job 把结果写到外部存储	不存	有独立列式存储层	重点是计算，数据通常在 S3 等外部存储
运维重量	Serverless	Serverless	比直接查 S3 更重	需选择和管理集群形态

Amazon Athena

- 直接对 S3 中的 JSON、CSV、Parquet 等数据执行 SQL，无需先搬入数据库。
- 适合 ad-hoc / on-demand 查询，即“需要时才查”。
- 通常按扫描数据量计费；列式格式、压缩和分区能减少扫描量。

AWS Glue

Glue 有三个主要部分：

1. **Data Catalog**：保存表名、Schema、字段类型、分区和 S3 路径等元数据，供 Athena、EMR、Redshift Spectrum 等读取。
2. **Crawler**：扫描 S3、RDS 或 JDBC 数据源，推断格式和字段，并更新 Data Catalog。
3. **ETL Job**：基于 Serverless Spark 或 Python Shell 做清洗、去重、转换和加载，例如把散乱的 CSV/JSON 合并为 Parquet。

ETL 的顺序是：**Extract（抽取）** → **Transform（清洗/转换）** → **Load（写入目标）**。

Amazon Redshift

- 分布式、列式的 OLAP 数据仓库，适合大量结构化数据上的复杂分析和频繁 BI 查询。
- 通常需把数据加载并组织到 Redshift；相比 Athena 直接查 S3，架构更重但更适合稳定分析负载。

Amazon EMR 与 Apache Spark

- EMR 用于运行 Spark、Hadoop、Hive 等框架；核心职责是大规模分布式计算，不是充当数据库。
- Spark 适合复杂 ETL 和大规模处理，简单 SQL 查询通常无需使用这么重的方案。
- Transient cluster：任务开始时创建，完成后删除，以减少空闲成本。

3.2 流数据：Kinesis Data Streams 与 Amazon Data Firehose

服务	核心目标	适合场景
Kinesis Data Streams	让应用实时消费数据流	多消费者、自定义实时处理、精细控制
Amazon Data Firehose (原 Kinesis Data Firehose)	托管式把流数据投递到目的地	低运维写入 S3、Redshift、OpenSearch 等

两者都可结合 Lambda 做转换。简单记忆：Streams 给应用消费，Firehose 帮你投递到存储或分析系统。

高吞吐 Clickstream 的典型链路是：API Gateway / 网站 → Kinesis Data Streams → Firehose → S3 / Redshift。S3 保存低成本原始数据，Redshift 承担结构化 OLAP 分析。

3.3 日志、搜索与 BI

- CloudWatch Logs：集中收集和监控 AWS 应用/系统日志；使用 Logs Insights 以查询语法分析日志。
- Amazon OpenSearch Service：适合全文搜索、日志分析和近实时 Dashboard；长期保存 TB 级历史数据通常比 S3 贵。
- Amazon QuickSight：AWS BI 与数据可视化服务，可连接 S3、Athena、RDS、Redshift 等。

QuickSight 的对象关系：

1	Data Source → Dataset → Analysis → Dashboard			
2	数据连接	数据集合	编辑分析	发布后的只读成品

Dashboard 通常共享给 QuickSight 用户或组；IAM Role 管理 AWS 资源权限，不等同于 QuickSight 内容共享。

3.4 托管 AI 服务

输入与任务	服务	要点
图片/视频中的物体、人脸、文字或不良内容	Amazon Rekognition	Content Moderation 返回标签和置信度；低置信度结果可进入人工审核
普通文本的情感、实体等 NLP 分析	Amazon Comprehend	面向自然语言，不处理视觉内容
PDF、扫描件中的文字、表格和表单键值	Amazon Textract	偏文档理解的 OCR
医疗文本中的疾病、药物、治疗或 PHI	Amazon Comprehend Medical	DetectPHI 用于识别受保护健康信息
需要自行训练和部署模型	Amazon SageMaker	灵活度高，但开发工作多于现成 AI API

医疗文件的常见处理链路：**PDF/JPEG** → **Textract** **提取文本** → **Comprehend Medical** **识别医疗实体或 PHI**。

4. 数据库与缓存

4.1 DynamoDB

容量模式

模式	适合流量	成本特点
On-Demand	不可预测、波动大	无需预设容量，按请求付费
Provisioned + Auto Scaling	稳定或大致可预测	预设 RCU/WCU，稳定高流量下通常更经济

扩展能力

- **Global Tables**：DynamoDB 原生多 Region、多活方案；各 Region 可读写，适合全球低延迟、高可用和灾备。
- **DAX**：DynamoDB 内存缓存，把热门数据读取降到微秒级；解决读延迟，不解决多 Region 灾备。
- **DynamoDB Streams**：记录 INSERT、UPDATE、DELETE 等变更，常触发 Lambda 做事件处理；不必用它自行重造 Global Tables 的复制能力。
- **Global Secondary Index (GSI)**：增加新的查询方式，但会额外消耗存储和读写资源；它不是容量成本优化功能。

恢复与长期备份

先区分两个指标：**RPO** 是最多可接受丢失多少数据，**RTO** 是故障后必须在多久内恢复。

需求	方案	要点
误删或数据损坏后恢复到精确时间点	DynamoDB PITR	持续自动备份，恢复窗口可设为 1-35 天；恢复时创建新表，不覆盖原表
数据必须合规保留多年	AWS Backup	用 Backup Plan 设置频率、生命周期和长期保留期
Region 故障时继续提供服务	Global Tables	跨 Region 多活复制，侧重高可用而非历史回滚

4.2 RDS 与 Aurora

读取扩展与高可用

能力	解决的问题	注意点
RDS Multi-AZ	高可用与自动故障切换	Standby 通常不能承担读流量
RDS Read Replica	报表、分析脚本等只读负载	异步复制、最终一致；应用必须连接 Reader，规格过小会造成复制延迟
Aurora Replica	读扩展与快速故障切换	可读，也可在 Writer 故障后提升为 Writer
Aurora Auto Scaling	读流量变化	自动增减 Replica，并配合 Reader Endpoint
RDS Proxy	连接池、减少连接风暴和故障切换影响	不保存业务数据，不能替代备份、HA 或消息缓冲

Aurora 的存储跨 3 个 AZ 保存多个副本，但只有一个 Writer Instance 时，实例故障仍需恢复计算层；在其他 AZ 部署 Aurora Replica 可缩短故障切换时间。

Aurora 的复制与回退功能

功能	用途
Aurora Clone	基于 copy-on-write 快速创建独立测试库，初始额外存储很少，避免全量导出拖累生产库
Aurora Backtrack	把原数据库回退到过去的时间点，无需从备份创建新库
Aurora Replica	持续同步的只读副本，用于读扩展和故障提升

数据库完全不可用而写入事件不能丢时，应在前面放 SQS 持久缓冲；RDS Proxy 只能管理连接，不能暂存待写数据。

非生产数据库的成本控制

做法	成本与恢复特点
Stop DB Instance	暂停计算费，但存储和快照仍收费；停止有期限，之后会自动启动
Snapshot + Delete	长期更省计算费，但恢复更慢、操作更多
Scale Down	只降低运行成本，数据库仍持续运行和计费

4.3 缓存与文件系统不要混淆

ElastiCache for Redis 是低延迟内存缓存/数据存储，不是共享持久文件系统；多台 EC2 需要共同访问文件时应考虑 EFS。缓存最适合重复、热点查询；低频且每次条件不同的报表通常命中率很低，应把只读负载导向 Read Replica。

5. 消息、事件与 Serverless

5.1 SQS 与 SNS

服务	模型	主要作用
Amazon SQS	消费者拉取队列	保存、缓冲、解耦消息
Amazon SNS	发布/订阅推送	将一条消息广播给多个订阅者

SQS 队列类型

- **Standard Queue**：强调高吞吐，不严格保证顺序，并采用 at-least-once delivery；消费者应做幂等，避免重复写入造成副作用。
- **FIFO Queue**：保证有序处理，并可用 Deduplication ID 抑制短时间内由生产者重复发送的消息，适合订单等顺序敏感场景。FIFO 去重不等于消费者永远不会重复执行。

可见性、轮询与保留期

机制	它控制什么	常见误区
Visibility Timeout	消息被取走后，对其他消费者隐藏多久	处理时间超过该值会使消息重新出现并被重复消费
ChangeMessageVisibility	动态延长某条正在处理的消息的隐藏时间	不是延长整个队列的保留期
Long Polling	消费者等待新消息多久，以减少空轮询	不控制消息处理时长
Message Retention	未删除消息能在队列中保留多久	最长 14 天，因此 SQS 不是长期归档系统

消费者应在处理成功后再调用 **DeleteMessage**。Lambda 消费 SQS 时，AWS 建议 Visibility Timeout 至少为函数 Timeout 的 6 倍；若配置 Batch Window，还要把它计入。Long Polling 最长为 20 秒。

常见组合

- 1 一条事件，多系统独立处理：Producer → SNS → SQS A / SQS B / SQS C
- 2
- 3 可靠异步处理： S3 或 SNS → SQS → Lambda
- 4
- 5 数据库写入跟不上： 请求 → SQS → DB Writer

- SNS 负责 fan-out，SQS 为每个消费者保留独立消息并提供缓冲、重试和恢复空间。
- S3 Event Notification 可在对象创建、删除等事件发生时通知 SNS、SQS、Lambda 或 EventBridge。通知按至少一次方式投递，可能重复或乱序；S3 不能直接把事件发到 SQS FIFO，需要经 EventBridge 等方式转接。
- Lambda 可通过 Event Source Mapping 自动轮询 SQS，不需要自建 EC2 Poller。
- Backpressure（背压）：生产速度超过消费速度时，Queue 暂存峰值，让消费者按能力处理，避免数据库被瞬时并发压垮。
- 异步 Worker 扩缩容应优先观察 ApproximateNumberOfMessagesVisible 或 Backlog per Instance（积压消息数 ÷ 运行实例数）；它比 CPU 更直接反映待处理任务压力。

上传后轻量处理的典型链路是：文件 → S3 Event → SQS → Lambda → S3 / DynamoDB。SQS 吸收波动，Lambda 自动伸缩，适合图片缩放、PDF 转换等无服务器任务。

5.2 定时任务与邮件

- 1 EventBridge Scheduler / Rule → Lambda 调 API、整理内容 → Amazon SES 发邮件
- EventBridge 负责每天或每小时等定时触发。
 - Lambda 负责调用 REST API、转换数据和生成 HTML。
 - Amazon SES 面向正式、可定制的 HTML 或批量邮件；SNS Email 更偏简单通知。

5.3 Serverless Web 架构

- 1 静态内容：用户 → CloudFront → S3
- 2 动态 API：用户 → API Gateway → Lambda → DynamoDB

这类架构可自动扩缩，适合突发大流量和低运维要求。

6. 网络、负载均衡与全球加速

6.1 三种全球访问能力

服务	优化对象	是否缓存	典型场景
CloudFront	内容分发	是	静态文件、可缓存 HTTP 内容
Global Accelerator	到 AWS Endpoint 的网络路径	否	动态 TCP/UDP、跨 Region 故障转移
S3 Transfer Acceleration	客户端上传到 S3	否	全球远距离上传单个目标桶

- **Route 53** 负责 DNS，把域名解析到 CloudFront、负载均衡器等目标。
- CloudFront 可配置多个 Origin，并按路径路由，例如 `/static/* → S3`、`/api/* → ALB`。
- **CloudFront Custom Origin** 可以是任何公网可达的 HTTP 源站，包括本地数据中心或其他云。即使内容不可缓存，CloudFront 仍可通过 Edge TLS 终止、连接复用和 AWS 骨干网加速动态网站。
- Route 53 的地理位置路由只决定“解析到哪个 Endpoint”；如果所有地区仍指向同一后端，它本身不会缩短网络路径。
- Global Accelerator 可根据用户位置和 Endpoint 健康状态，在多个 Region 间选择目标。

6.2 ALB、NLB 与 GWLB

负载均衡器	协议/对象	典型用途
ALB	HTTP/HTTPS	Web 与基于路径/主机的路由
NLB	TCP/UDP/TLS	高性能网络流量、UDP、VoIP、游戏、DNS
GWLB	第三方网络虚拟设备	防火墙、IDS/IPS、深度包检查

Gateway Load Balancer Endpoint (GWLBe) 是 VPC 接入 GWLB 的入口，可通过路由把流量透明送往第三方安全设备。全球 UDP、低延迟且需要跨区故障转移时，常组合 **NLB + Global Accelerator**。

ALB 的两个常用应用层功能：

- **HTTP → HTTPS**：在 80 端口 Listener 配置 Redirect Action，重定向到 443；NACL 只能放行/拒绝，不能做 HTTP 重定向。
- **Health Check Path**：定期请求 `/health` 等路径，根据 HTTP 状态把 Target 标为 unhealthy；ASG 可使用 Load Balancer Health Check 自动替换应用已坏但操作系统仍存活的 EC2。

6.3 VPC Endpoint：私有访问 AWS 服务

类型	Gateway Endpoint	Interface Endpoint (PrivateLink)
支持范围	S3、DynamoDB	大量 AWS 和合作伙伴服务
实现方式	在 Route Table 中加入路由	在子网创建带私有 IP 的 ENI
费用	Endpoint 本身无小时费和数据处理费	按小时和数据量收费
On-prem 经 DX/VPN 访问	不适用	可以
访问控制	Endpoint Policy、路由与资源策略	Security Group 和 Endpoint Policy

S3 Gateway Endpoint 可避免 Private EC2 经 NAT Gateway 访问 S3 的处理费。若要限制桶只能从指定私有路径访问，可在 Bucket Policy 使用 `aws:SourceVpce` 或 `aws:SourceVpc`；不要把长期 IAM User Access Key 复制到 EC2，应使用 IAM Role。

6.4 Security Group 与 Bastion

- Security Group 是 **Stateful** 的，只写 Allow 规则；允许请求进入后，返回流量自动放行。
- SG 可把另一个 SG 作为来源，无需写死会随 Auto Scaling 改变的实例 IP。
- 典型数据库规则：**App-SG → DB-SG：数据库端口**；Microsoft SQL Server 默认使用 TCP 1433。
- Bastion 的 22 端口只允许公司公网 IP/CIDR；Private EC2 的 22 端口只允许 Bastion-SG。更低运维的远程管理可使用 Session Manager。
- Route Table 决定“流量往哪里走”，不能替代 SG 表达“哪组应用实例可访问数据库”。

6.5 域名与 TLS 证书

API Gateway 自定义域名的典型组合是：**ACM Certificate + API Gateway Custom Domain + Route 53 Alias**。

Endpoint/证书场景	证书位置或续期责任
Regional API Gateway	ACM 证书与 API 位于同一 Region
Edge-Optimized API Gateway	ACM 证书位于 us-east-1
ACM 签发的公网证书	满足托管续期条件时由 ACM 自动续期
外部 CA 证书导入 ACM	可挂载到 ALB 等服务，但需自行更新并重新导入

ACM Private CA 用于建立企业私有 CA，不是替外部 CA 证书接管自动续期。

6.6 本地到 AWS 的连接

连接方式	网络路径	特点
Site-to-Site VPN	公网上的加密隧道	部署快、成本低，但占用 Internet 带宽
AWS Direct Connect	到 AWS 的专线	适合长期、大量传输，带宽和延迟更稳定

成本敏感的混合云高可用常使用 **Direct Connect 主线路 + Site-to-Site VPN 备份**；若要求故障时仍保持高带宽，则应考虑不同连接或 Location 的冗余 DX，成本也更高。

7. 身份、密钥与安全

7.1 IAM 与多账号身份

EC2 获取 AWS 权限

给 EC2 附加 IAM Role 是标准做法。EC2 实际通过 **Instance Profile** 取得自动轮换的临时凭证，不应为实例创建 IAM User 或写死长期 Access Key。

AWS Organizations 条件键

条件键	控制粒度	适用场景
<code>aws:PrincipalOrgID</code>	整个 Organization	允许组织内所有账号访问
<code>aws:PrincipalOrgPaths</code>	指定 OU 路径	只允许某些组织单元访问
<code>aws:PrincipalTag</code>	Principal 标签	用 ABAC 按属性授权，但需维护标签

IAM Identity Center

AWS IAM Identity Center（原 AWS SSO）提供一个入口访问多个 AWS Account，并集中分配账号权限。它可与 AWS Directory Service for Microsoft AD 及本地 AD 信任关系集成；one-way trust 是单向信任，two-way trust 是双方互信。

7.2 凭证与参数管理

服务	适合内容	关键能力
AWS Secrets Manager	数据库密码、API Key 等 Secret	原生自动轮换；可集成 RDS/Aurora
SSM Parameter Store	应用配置和普通 Secret	统一参数管理，但没有 Secrets Manager 那样的内建自动轮换

应用应通过 IAM Role 在运行时读取 Secret，不要把凭证写死在文件中。Secrets Manager 单个 Secret 最大 64 KB，并可把 Secret 复制到其他 Region，便于多 Region 应用读取本地副本。

7.3 加密与多 Region 密钥

- **SSE-S3**：由 S3 管理服务器端加密密钥。
- **SSE-KMS**：使用 KMS Key，可控制 Key Policy 并获得更细的审计能力。
- **KMS Multi-Region Key**：在其他 Region 建立共享相同 key material 的 Replica Key，实现跨区加解密兼容；各 Region 仍是独立的 KMS Key 资源。
- **直接加密与信封加密**：使用对称 KMS Key 时，`Encrypt` API 最多直接处理 4 KB；更大数据应使用 `GenerateDataKey`，由数据密钥加密正文，再用 KMS Key 保护数据密钥。

跨账号共享加密 AMI

EBS-backed AMI 的底层包含 EBS Snapshot，因此共享由客户管理 KMS Key 加密的 AMI 需要两层授权：

1. 在 AMI `launchPermission` 中允许目标 AWS Account 使用 AMI。
2. 通过 KMS Key Policy 或 Grant 允许目标账号使用原加密 Key。

目标账号随后可复制 AMI，并改用自己的 KMS Key 重新加密。加密 AMI/Snapshot 不能直接设为 Public。

7.4 网络与威胁防护

服务	它解决什么	它不是什么
AWS Network Firewall	在 VPC 流量路径上做有状态检查和 Allow/Deny	不是单纯告警工具
GuardDuty	分析日志并发现可疑行为	不是 inline 防火墙
VPC Traffic Mirroring	复制 ENI 流量给安全设备旁路分析	不直接阻断原流量
Firewall Manager	跨账号集中管理安全策略	本身不转发或检查数据包
AWS Shield	防御 DDoS	不是漏洞扫描器

Shield Standard 默认提供常见 Layer 3/4 DDoS 防护；Shield Advanced 是面向重要生产系统的付费高级防护，提供更强检测、响应支持等能力。

7.5 数据与漏洞检查

目标	服务
在 S3 中发现 PII、信用卡号等敏感数据	Amazon Macie
检查 EC2、Lambda、容器镜像中的软件漏洞/CVE	Amazon Inspector

8. 监控、审计、合规与成本

8.1 Config、CloudTrail、Trusted Advisor

服务	回答的问题	示例
AWS Config	资源配置变成了什么？是否合规？	安全组开放了 22；S3 加密被关闭；资源缺少 Tag
AWS CloudTrail	谁在何时调用了什么 AWS API？	谁执行了 <code>DeleteBucket</code>
AWS Trusted Advisor	当前环境有哪些最佳实践改进建议？	成本、安全、性能、容错、服务限额建议

Config 的 `required-tags` Rule 可把缺少指定标签的资源标为 `NON_COMPLIANT`。Cost Explorer 虽能按 Cost Allocation Tag 分析费用，但不负责标签合规检查。

证书到期需要以合规规则统一检查时，可使用 Config 托管规则 `acm-certificate-expiration-check`：

```
1 Config 判定证书即将到期 → EventBridge 捕获合规状态变化 → SNS 通知
```

这对需要自行续期的 ACM Imported Certificate 尤其重要。ACM 也会直接向 EventBridge 发送 `Certificate Approaching Expiration` 事件；默认提前期因证书类型而异，并可通过 ACM 账户配置调整，不应再记成固定 45 天。

8.2 CloudWatch Dashboard Sharing

CloudWatch Dashboard 可共享给只需查看监控信息的外部人员，无需为了一个 Dashboard 授予整个 AWS Console 的广泛权限；这符合最小权限原则。

8.3 成本工具

需求	工具
分析历史费用、定位某月费用上涨原因	AWS Cost Explorer
超过金额或用量阈值时告警	AWS Budgets
获取最详细的账单原始数据	Cost and Usage Report (CUR)

CUR 可导出到 S3，再用 Athena 或 QuickSight 深入分析；能力最强，但搭建复杂度也更高。

9. 计算容量与系统运维

9.1 EC2 购买与容量选项

方案	适合场景	核心取舍
On-Demand	用量不确定、间歇运行的开发测试	无长期承诺，单价较高
Reserved Instance / Savings Plans	稳定、长期、7×24 工作负载	用 1 年或 3 年承诺换折扣
Spot	可中断、无状态、可重试的批处理	价格低，但容量可被回收
Dedicated Host / Instance	合规、隔离或 BYOL 许可	成本较高
On-Demand Capacity Reservation	必须保证指定 AZ 有实例可启动	关注容量保证，不等同于价格折扣

记忆重点：RI/Savings Plans 关注“用得便宜”，Capacity Reservation 关注“开得出来”。每天只运行数小时且能自动停机的环境，通常更适合 On-Demand；生产 Web/数据库不能因为 Spot 便宜就忽略中断风险。

9.2 Auto Scaling 与启动配置

- Auto Scaling Group (ASG) 可跨多个 AZ 放置实例，避免单 AZ 故障使应用完全中断。
- Launch Template 定义新实例配置，支持版本、混合实例等新能力，是当前首选。
- Launch Configuration 是旧式方案，已不支持新的实例类型；2024-10-01 之后创建的账号不能再创建它。新架构应使用 Launch Template。
- ASG 可结合 Target Group Health 自动替换应用层不健康的实例，也可依据 SQS backlog 等业务指标伸缩。

9.3 ECS 与 Fargate

运行方式	用户负责	适用情况
ECS on EC2	容器之外，还要管理 EC2 容量、OS、补丁和伸缩	需要控制底层实例或特殊容量
ECS on Fargate	定义容器、CPU、内存和网络	希望使用 Serverless Container、减少基础设施运维

ECS 是 AWS 容器编排服务；EKS 面向 Kubernetes。若应用没有 Kubernetes 需求，为了“容器化”而引入 EKS 会增加不必要的运维复杂度。

9.4 Systems Manager 工具

工具	职责
Session Manager	安全远程连接 EC2，无需开放 22、管理 SSH Key 或部署 Bastion
Patch Manager	按 Patch Baseline 扫描和安装标准系统补丁
Maintenance Windows	规定维护任务何时执行
Run Command	无需 SSH，批量执行 Shell/PowerShell 或安装自定义软件
OpsCenter	汇总和处理运维事件 (OpsItems)，不是 Secret 存储服务

使用 Session Manager 的 EC2 通常需要 SSM Agent、IAM Role，以及访问 Systems Manager Endpoint 的网络路径；会话还可被记录以便审计。